

SENTRY

A 3-in-1 Static Security Configuration Linter

USER MANUAL

sshd • nginx • docker-compose

Course Mini Project — Custom Ethical Hacking Tool

Hood Security Department • NSSECU2 (S04) • Version 0.1.0

Static analysis only — this tool never connects to a live system.

1. Introduction

Sentry is a **static security configuration linter**. You point it at a configuration file and it reports insecure settings, insecure defaults, and missing hardening directives, each with a severity, a plain-language explanation, and a suggested fix. It supports three configuration formats through a single engine: OpenSSH server configs (`sshd_config`), `nginx` configs, and `docker-compose` files.

Sentry performs **static analysis only**: it reads configuration text and never connects to, scans, probes, or tests any running system, service, or network. This makes it safe to run anywhere, including in a lab or classroom setting.

2. System Requirements

Requirement	Detail
Python	Version 3.10 or newer (developed and tested on 3.12)
Operating system	Linux, macOS, or Windows 11 / 10
Dependencies	<code>pyyaml>=6.0</code> and <code>rich>=13.0</code>
Internet	Only needed once, during installation, to download the two dependencies
Disk / privileges	Negligible; no administrator or root privileges required

3. Installation

Unzip the project and open a terminal in the project folder (the folder that contains `pyproject.toml`).

Option A — recommended (installs the sentry command)

```
python -m venv .venv
# Linux / macOS:
source .venv/bin/activate
# Windows (PowerShell):
.venv\Scripts\Activate.ps1

pip install -e .
sentry --version
```

Option B — no install, dependencies only

Install the two dependencies and run the tool as a Python module. With this option, use `python -m sentry` wherever this manual writes `sentry`.

```
pip install -r requirements.txt
python -m sentry --version
```

Running on Windows 11 (PowerShell)

Windows 11 works the same way, with a few platform notes that prevent the most common problems:

Install Python from PATH. Install Python 3.10 or newer from python.org and, on the first installer screen, tick “Add python.exe to PATH”. Then close and reopen PowerShell. This prevents the most common “sentry: command not found” and “python is not recognized” errors.

If activation is blocked. If PowerShell refuses to run `.venv\Scripts\Activate.ps1` with a message that running scripts is disabled, allow it for your user account only, then run the activate command again:

```
Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy RemoteSigned
```

Alternatively, skip the virtual environment entirely and use Option B above (`python -m sentry`), which does not require activation.

Paths and wildcards. Use backslashes in file paths. PowerShell does *not* expand a `samples\*.bad` wildcard, so list files explicitly:

```
sentry samples\sshd_config.bad
sentry samples\nginx.conf.bad samples\docker-compose.bad.yml --min-severity high
```

Checking the exit code. On Windows use `echo $LASTEXITCODE` (not `$?`). It prints 1 when high-severity findings are present and 0 when clean.

Colored output. Run the tool in **Windows Terminal** (built into Windows 11) for correct colored output. The classic `cmd.exe` console may not render colors. To open the HTML report from PowerShell, run `start report.html`.

4. Usage

Point Sentry at one or more files. It detects the config type from the filename, or you can force it with `--type`. The examples below use forward slashes; on Windows PowerShell use backslashes (see section 3).

Common commands

```
# Scan a single file (type auto-detected)
sentry samples/sshd_config.bad

# Scan several files of mixed types at once
sentry samples/sshd_config.bad samples/nginx.conf.bad samples/docker-
compose.bad.yml

# Show only high-severity issues
sentry samples/nginx.conf.bad --min-severity high

# Produce a shareable HTML report
sentry samples/nginx.conf.bad --format html --output report.html

# List every bundled rule
sentry --list-rules
```

Options

Flag	Purpose
<code>-t, --type</code>	Force a config type (sshd, nginx, docker-compose) instead of auto-detecting

Flag	Purpose
<code>-f, --format</code>	Output format: console (default), json, or html
<code>-o, --output</code>	Write the report to a file instead of the screen
<code>--min-severity</code>	Hide findings below this severity (default: info)
<code>--fail-on</code>	Exit with code 1 if any finding is at or above this severity (default: high)
<code>--list-rules</code>	Print every bundled rule and exit
<code>--version</code>	Print the version and exit

Exit codes

Sentry sets its exit code so it can be used unattended in a CI pipeline:

Code	Meaning
0	No findings at or above the <code>--fail-on</code> threshold
1	Findings at or above the threshold were reported
2	Usage or input error (missing file, unknown type, etc.)

5. Understanding the Results

Each finding has four parts: a **severity**, a **rule ID and title**, a **detail line** saying what was found and where, and a **fix**. A reference to a recognised benchmark (CIS, OWASP, Mozilla) is included where applicable.

Severity levels

Severity	Meaning
HIGH	Serious weakness that should be fixed before deployment
MEDIUM	Meaningful weakness worth addressing
LOW	Minor hardening improvement or defence-in-depth
INFO	Informational note, no direct risk

Note that a *missing* hardening directive is reported as a finding in its own right, because relying on an insecure default is itself a security problem.

6. Sample Run

Scanning the deliberately-weak nginx sample produces the following report. Nine issues are found and grouped by severity, each with the exact line, an explanation, and a fix:

```
sentry samples/nginx.conf.bad
samples/nginx.conf.bad (nginx)
HIGH NGX-001 Deprecated TLS/SSL protocol versions enabled
line 10: contains disallowed value(s): TLSv1, TLSv1. 1
fix: Use only modern protocols: 'ssl_protocols TLSv1.2 TLSv1.3;'
ref: Mozilla SSL Configuration Generator

HIGH NGX-003 Missing HTTP Strict Transport Security (HSTS) header
config: no matching directive sets 'Strict-Transport-Security'
fix: Add 'add_header Strict-Transport-Security "max-age=63072000; includeSubDomains"
always;'
ref: OWASP Secure Headers Project

HIGH NGX-008 Weak SSL cipher suite string
line 11: contains disallowed value(s): NULL, RC4, MD5, aNULL
fix: Restrict 'ssl_ciphers' to a modern list (e.g. Mozilla intermediate ).
ref: Mozilla SSL Configuration Generator

MEDIUM NGX-004 Missing X-Frame-Options / frame-ancestors protection
config: no matching directive sets 'X-Frame-Options'
fix: Add 'add_header X-Frame-Options "SAMEORIGIN" always;'
ref: OWASP Secure Headers Project

MEDIUM NGX-007 Directory autoindex is enabled
line 4: found 'on', expected 'off'
fix: Set 'autoindex off;' (or remove the directive ).
ref: nginx autoindex module

LOW NGX-002 Server version banner is exposed
line 3: found 'on', expected 'off'
fix: Add 'server_tokens off;'
ref: nginx core module docs

LOW NGX-005 Missing X-Content-Type-Options header
config: no matching directive sets 'X-Content-Type-Options'
fix: Add 'add_header X-Content-Type-Options "nosniff" always;'
ref: OWASP Secure Headers Project

LOW NGX-006 Server does not prefer its own cipher order
line 12: found 'off', expected 'on'
fix: Add 'ssl_prefer_server_ciphers on;'
ref: Mozilla SSL Configuration Generator

LOW NGX-009 TLS session tickets are enabled
line 13: found 'on', expected 'off'
fix: Set 'ssl_session_tickets off;'
ref: Mozilla server-side TLS guidance

Summary
9 finding(s): 3 HIGH 2 MEDIUM 4 LOW
```

Figure 1 — Console output for `sentry samples/nginx.conf.bad`

The same scan can be written to a self-contained HTML report with `--format html --output report.html`, which opens in any web browser and is useful for sharing or including in a report.

7. How It Works

Sentry normalises all three config formats into one common shape and evaluates them with a single, generic rule engine. All security knowledge lives as data in YAML rulesets, so adding a check does not require changing the engine code.

Sentry — System Architecture

One data-driven engine, three configuration formats. Static analysis only — no network access.

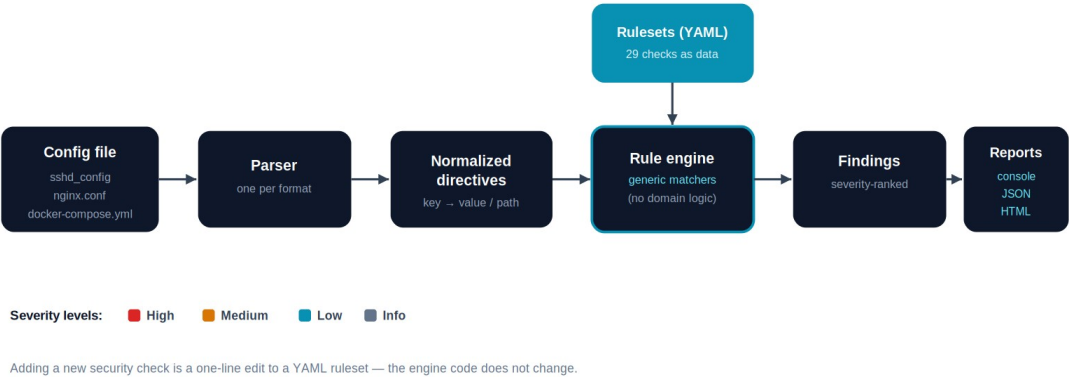


Figure 2 — Processing pipeline

8. Troubleshooting

Symptom	Resolution
“sentry: command not found”	Use Option A (pip install -e .) so the command is created, or run python -m sentry instead.
“python is not recognized” (Windows)	Python is not on PATH. Reinstall Python and tick “Add python.exe to PATH”, then reopen PowerShell.
“running scripts is disabled” (Windows)	Run: Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy RemoteSigned, then activate again.
“cannot determine config type”	The filename was not recognised. Add --type sshd nginx docker-compose.
ModuleNotFoundError: rich / yaml	Dependencies are not installed. Run pip install -r requirements.txt.
No colour in the output	Expected when output is piped; on Windows, use Windows Terminal rather than cmd.exe.

9. Limitations

Sentry is a deliberately small, educational tool and is not a replacement for mature scanners. It ships with roughly 29 rules across three formats; it does not have CVE or version-vulnerability awareness; its nginx parsing is directive-level rather than fully block-scoped; its secret detection is pattern-based and may miss unusually named secrets; and findings for docker-compose files do not carry line numbers.

10. Ethical Reminder

This tool was developed for educational purposes only. It must only be used in authorized and controlled testing environments. Unauthorized testing against real systems, public websites, or third-party services is strictly prohibited.

Sentry performs static analysis of configuration text you provide. It does not connect to, scan, or test any live system. You are responsible for ensuring you have permission to review any file you run it against.